

Segurança em redes de computadores

SEG786203 – CST em Análise e Desenvolvimento de Sistemas

Prof. Emerson Ribeiro de Mello

mello@ifsc.edu.br

Licenciamento

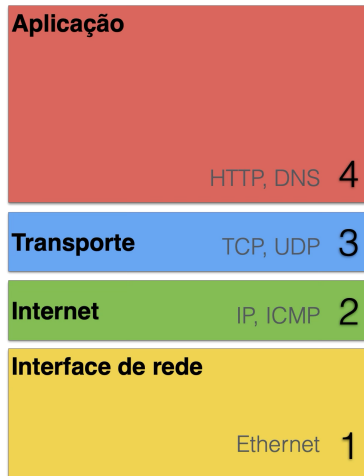


Slides licenciados sob [Creative Commons "Atribuição 4.0 Internacional"](https://creativecommons.org/licenses/by/4.0/)

Modelo OSI e TCP/IP

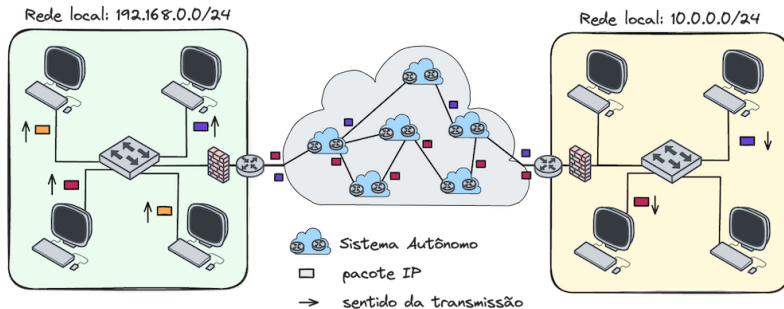


Modelo OSI



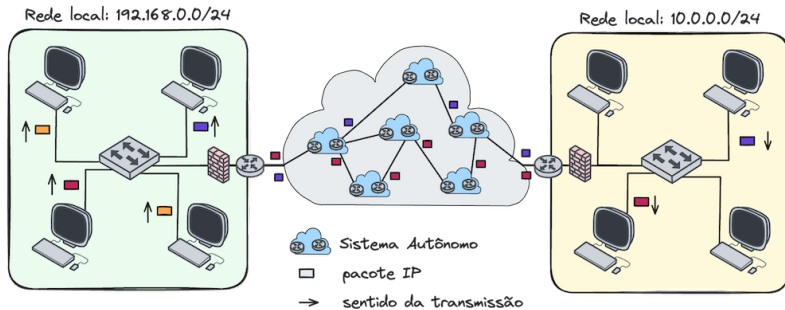
Arquitetura TCP/IP

Redes de computadores



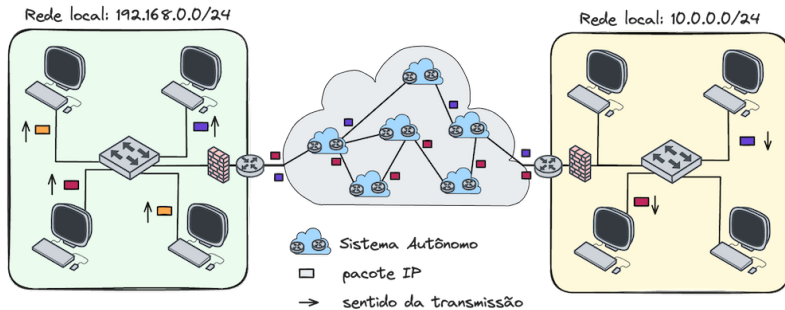
- Dispositivo final
- Switch (comutador)
- Roteador
- *Firewall*

Redes de computadores



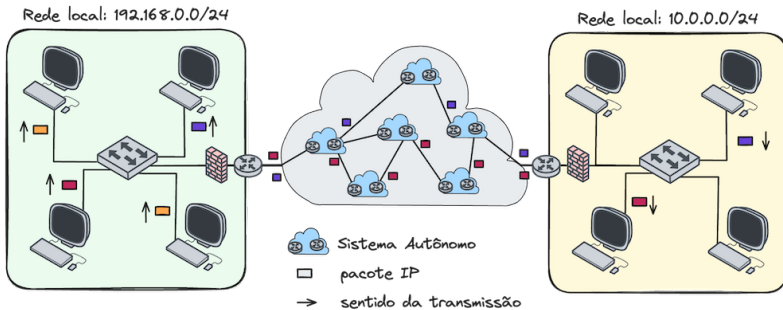
- O caminho do pacote até o destino é chamado de **rota**
- A comunicação entre dois dispositivos é uma **sessão**
- Todos os pacotes de uma sessão seguem sempre a mesma rota?

Redes de computadores



- O pacote pode ser interceptado em qualquer ponto da rota:
 - Origem, rede local, roteador, rede de destino ou destino
- Como garantir confidencialidade, integridade e autenticidade dos dados?

Redes de computadores



- Um servidor está associado a uma porta, protocolo e endereço IP
- É possível limitar o acesso ao servidor apenas para máquinas da rede local?
- É possível permitir acesso somente de uma máquina específica?

Endereçamento I

- O **endereço MAC** é gravado na ROM da placa de rede pelo fabricante e é utilizado para identificar a placa de rede em uma rede local
- O **endereço IP** é associado a uma interface de rede e é utilizado para identificar um dispositivo em uma rede TCP/IP

Endereçamento II

```
root@73436e94eae1:~# ip a
```

```
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
4: eth0@if5: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:ac:11:00:02 brd ff:ff:ff:ff:ff:ff link-netnsid 0
    inet 172.17.0.2/16 brd 172.17.255.255 scope global eth0
        valid_lft forever preferred_lft forever
```

Interface de rede

MAC

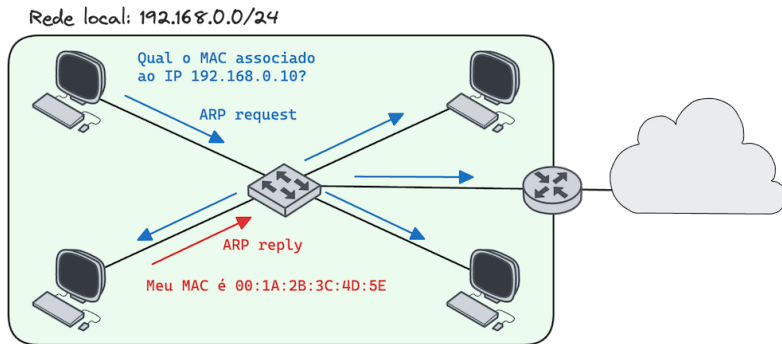
IPv4

IPv6

Endereçamento III

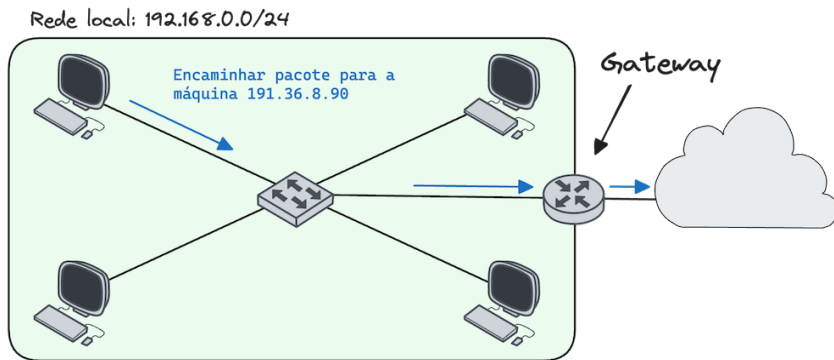
- Dois dispositivos não podem ter o mesmo endereço MAC no mesmo domínio de *broadcast*.
- Dois dispositivos não podem ter o mesmo endereço IP na mesma rede TCP/IP.
- O endereço IP serve para roteamento entre redes; o endereço MAC identifica o dispositivo na rede local.
- O protocolo ARP (*Address Resolution Protocol*) converte endereços IP em endereços MAC.
 - ARP associa um endereço IPv4 a um endereço físico MAC.

Endereçamento IV



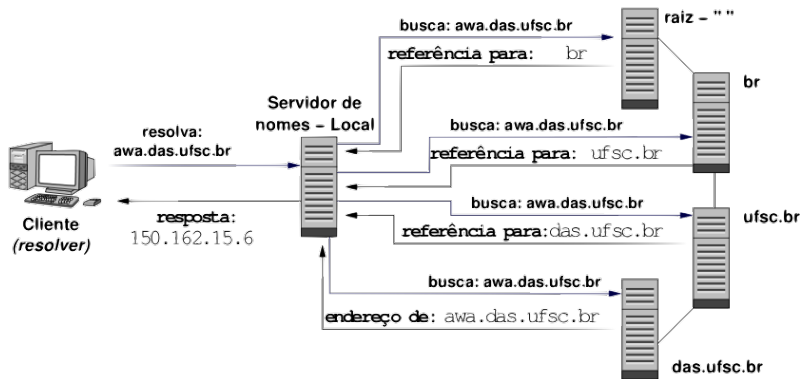
- Consulta feita em ***broadcast*** e o dispositivo com o endereço IP solicitado responde com seu endereço MAC (***unicast***)
- Os dispositivos mantêm uma tabela ARP com os endereços IP e MAC dos dispositivos da rede (*ARP cache*)

Endereçamento V



- O dispositivo de origem encaminha o pacote para o *gateway* padrão, uma vez que o destino não está na mesma rede
- E como o dispositivo de origem descobriu o endereço IP do destino?

Endereçamento VI



- Serviço de nomes de domínio (DNS) é responsável por associar um nome de domínio a um endereço IP
- Resolução: recursiva e iterativa

Rede Virtual Privada

Virtual Private Network (VPN)

VPN

Rede privada que utiliza a infraestrutura de uma rede pública para estabelecer conexões seguras (túneis criptografados) entre dispositivos

- Pode ser do tipo
 - **VPN de acesso remoto**
 - **VPN de site a site**
 - **VPN pessoal**

Rede Virtual Privada

VPN de acesso remoto



- Usuários acessam a rede corporativa remotamente, como se estivessem no local.

Rede Virtual Privada

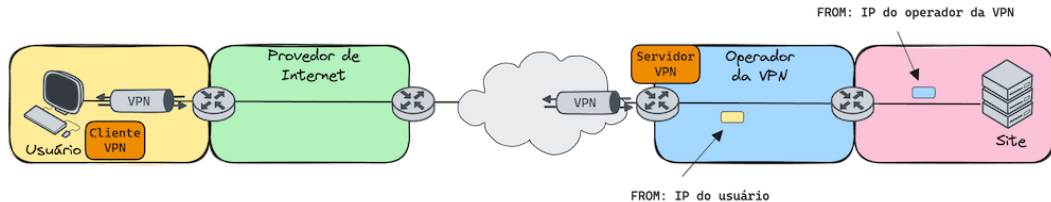
VPN de site a site



- Filiais se conectam de forma segura, compartilhando recursos como se estivessem na mesma rede.

Rede Virtual Privada

VPN pessoal



- VPN pessoal protege a navegação em redes públicas, mas o operador da VPN pode monitorar o tráfego.
- A velocidade pode ser reduzida, uma vez que o tráfego é roteado através de servidores da VPN.

Firewall

Definição convencional: Parede corta fogo

Dispositivo feito de material a prova de fogo para evitar que o fogo se espalhe de uma parte do edifício para outra

Firewall

Definição convencional: Parede corta fogo

Dispositivo feito de material a prova de fogo para evitar que o fogo se espalhe de uma parte do edifício para outra

Definição para sistemas computacionais

Ponto de controle que mantém acessos não autorizados fora do perímetro de segurança, ao mesmo tempo possibilita acesso aos sistemas externos

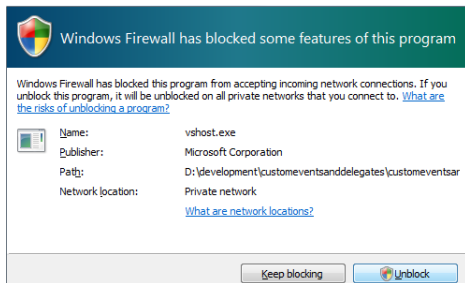
- Evita que potenciais vulnerabilidades de serviços sejam exploradas
 - Nenhum software complexo é 100% seguro

Firewall de máquina (ou Firewall pessoal)

- **Perímetro de segurança:** A própria máquina
- Analisa todo o tráfego entrante e saindo
 - Uma forma de proteção contra *spywares*, máquinas zumbis
- As regras podem seguir uma política de segurança da organização (mais seguro) ou o próprio usuário pode definir suas regras (menos seguro)
- **Exemplo:** Firewall do Microsoft Windows

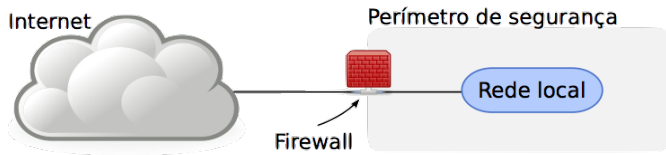
Firewall de máquina (ou Firewall pessoal)

- **Perímetro de segurança:** A própria máquina
- Analisa todo o tráfego entrante e saindo
 - Uma forma de proteção contra *spywares*, máquinas zumbis
- As regras podem seguir uma política de segurança da organização (mais seguro) ou o próprio usuário pode definir suas regras (menos seguro)
- **Exemplo:** Firewall do Microsoft Windows



Firewall de rede

- **Perímetro de segurança:** toda a rede local da organização
- Todo o tráfego entre a rede interna e externa passa obrigatoriamente pelo firewall
- Apenas o tráfego autorizado pela política de segurança é permitido
- O firewall deve ser resistente a invasões
 - Requer sistema operacional seguro e apenas serviços essenciais ativos



Características de um firewall de rede

- Centraliza o controle de acesso, aumentando a segurança da rede
 - Protege mesmo que os computadores dos usuários não estejam totalmente seguros
- É o local ideal para aplicar NAT e registrar o tráfego
- **Não protege** contra ataques vindos da própria rede interna
- **Não impede** que máquinas internas usem modems (5G) para acessar a Internet diretamente

Características de um firewall de rede

- Centraliza o controle de acesso, aumentando a segurança da rede
 - Protege mesmo que os computadores dos usuários não estejam totalmente seguros
- É o local ideal para aplicar NAT e registrar o tráfego
- **Não protege** contra ataques vindos da própria rede interna
- **Não impede** que máquinas internas usem modems (5G) para acessar a Internet diretamente

Firewall pessoal + Firewall de rede

O firewall de rede protege contra ameaças externas; o firewall pessoal protege contra ataques internos.

Tipos de Firewall

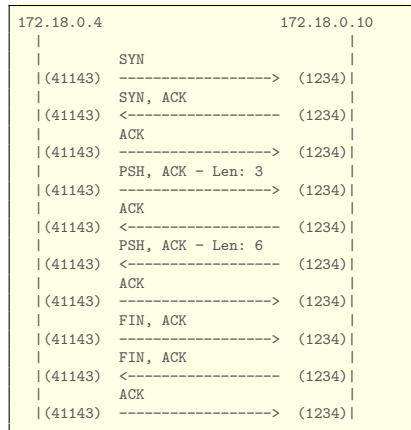
- **Filtro de pacotes** (camada de rede)
 - Se preocupa com endereço IP de origem/destino, porta de origem/destino, protocolo utilizado
 - Geralmente combinado com roteador
- **Inspeção de estado** (camada de transporte)
 - Não filtram pacotes individuais, o filtro é baseado em regras de sessões
- **Gateway no nível de aplicação**
 - O tráfego é analisado na camada de aplicação
- **Web Application Firewall (WAF)**
 - Inspecciona o tráfego HTTP

Filtro de pacotes

- Atua na camada de rede e não se preocupa com o conteúdo dos pacotes
- Analisa todo datagrama e decide se serão descartados ou encaminhados
 - Endereço IP de origem e de destino
 - Porta de origem e de destino
 - Interface de entrada e de saída
 - Protocolo TCP, UDP ou ICMP

Inspeção de estado

- Atua na camada de transporte (camada 4)
- Não analisa pacotes individuais
- Mantém estado de todas as conexões que passam por este
 - TCP *Flags*: SYN, ACK...



Gateway no nível de aplicação

Filtragem na camada 7 (aplicação)

- Permite controle detalhado do tráfego, analisando o conteúdo dos pacotes
 - Exemplo: bloquear downloads de arquivos .EXE para usuários internos
 - Pode integrar antivírus para inspeção adicional
- Exige mais processamento que filtros de pacotes ou de sessões
- Atua como intermediário:
 - 1 Recebe e analisa os pacotes dos clientes
 - 2 Se aprovados, estabelece nova conexão com o servidor externo

Web Application Firewall (WAF)

- Firewall especializado em proteger aplicações web.
- Bloqueia ataques como *SQL Injection*, *Cross-Site Scripting (XSS)*, *Cross-Site Request Forgery (CSRF)* e reduz riscos de DoS
- Serviços de CDN como Akamai e Cloudflare oferecem WAF com regras atualizadas para novas ameaças
- Pode detectar vazamento de dados e uso de credenciais comprometidas

Comparativo entre os tipos de firewall

- Filtro de pacotes
- Inspeção de estados
- Gateway de aplicação

Comparativo entre os tipos de firewall

■ Filtro de pacotes

- **Vantagens:** Com regras simples é possível se proteger da maioria das ameaças de segurança
- **Desvantagens:** Segurança vs facilidade para usuários

■ Inspeção de estados

■ Gateway de aplicação

Comparativo entre os tipos de firewall

■ Filtro de pacotes

- **Vantagens:** Com regras simples é possível se proteger da maioria das ameaças de segurança
- **Desvantagens:** Segurança vs facilidade para usuários

■ Inspeção de estados

- **Vantagens:** Evita ataques mais elaborados; facilidade para usuários
- **Desvantagens:** Aplicações UDP não são atendidas

■ Gateway de aplicação

Comparativo entre os tipos de firewall

■ Filtro de pacotes

- **Vantagens:** Com regras simples é possível se proteger da maioria das ameaças de segurança
- **Desvantagens:** Segurança vs facilidade para usuários

■ Inspeção de estados

- **Vantagens:** Evita ataques mais elaborados; facilidade para usuários
- **Desvantagens:** Aplicações UDP não são atendidas

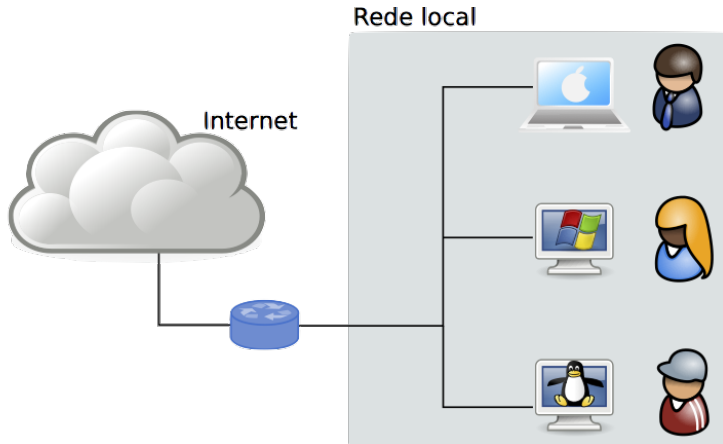
■ Gateway de aplicação

- **Vantagens:** Filtro granular baseado em conteúdo
- **Desvantagens:** Não é adequado para aplicações que necessitam de baixa latência

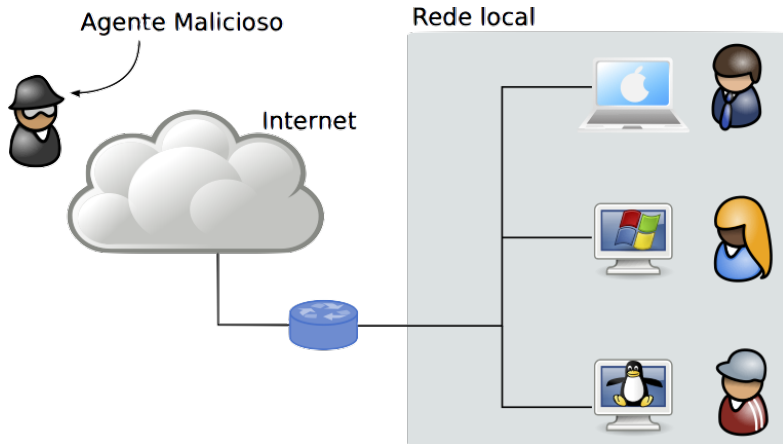
Estratégias de implementação de firewall

Estratégia	Descrição
Local	Instalado em cada máquina individual
Roteador/Firewall	Uma única máquina para roteamento e filtragem de pacotes
<i>Firewall</i> com 2 interfaces	Intermedia a conexão entre a LAN e o roteador
Firewall com subredes	Máquinas da rede interna são alocadas em diferentes subredes
2 Firewalls com subredes	Separação de tarefas por 2 firewalls

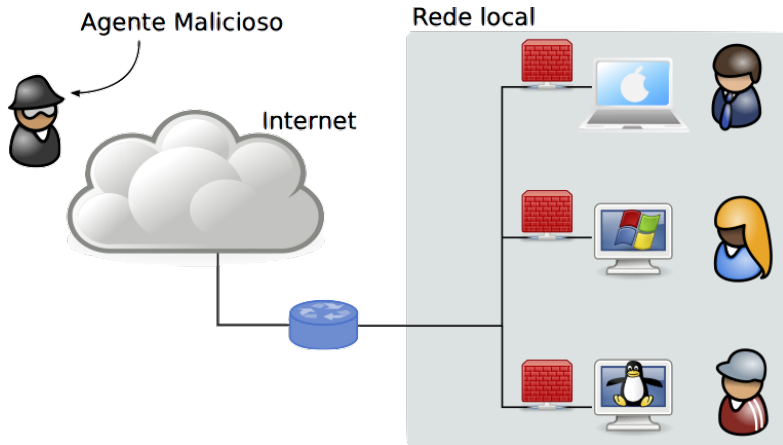
Estratégia: Local



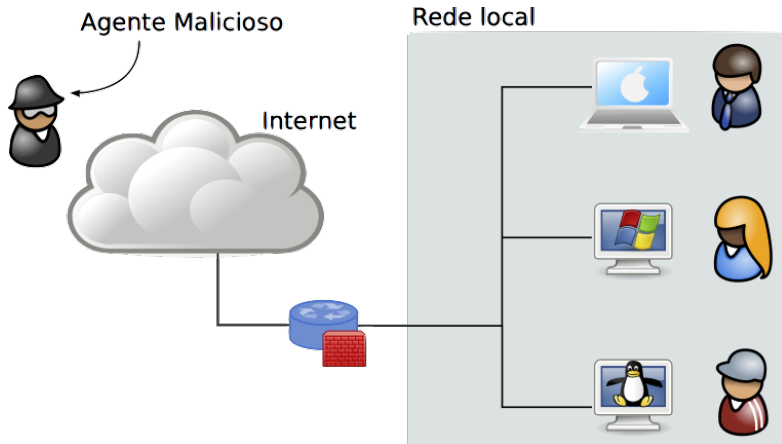
Estratégia: Local



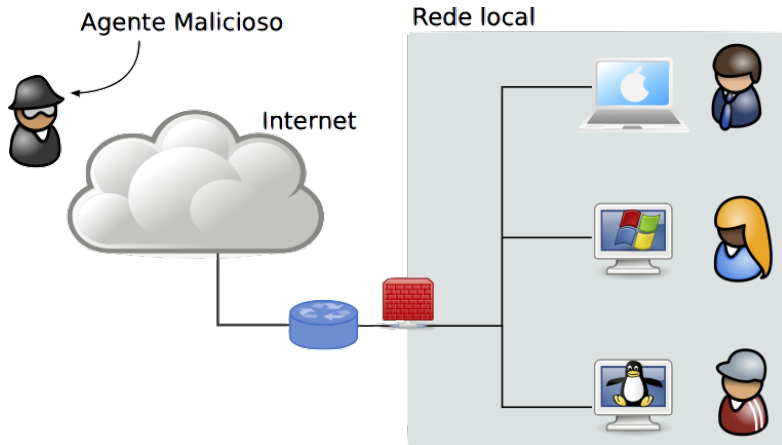
Estratégia: Local



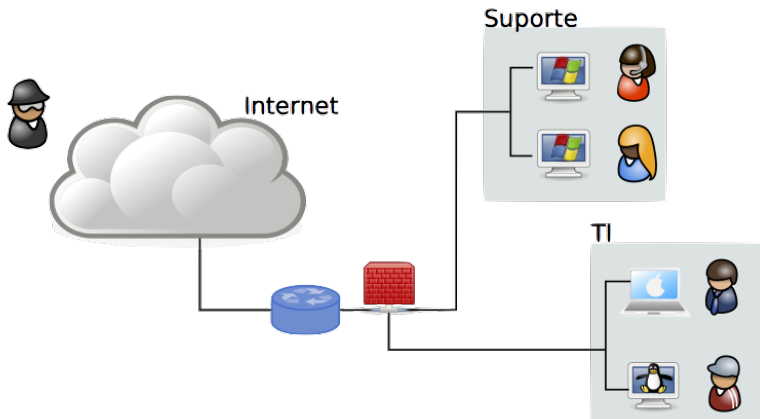
Estratégia: Roteador/Firewall



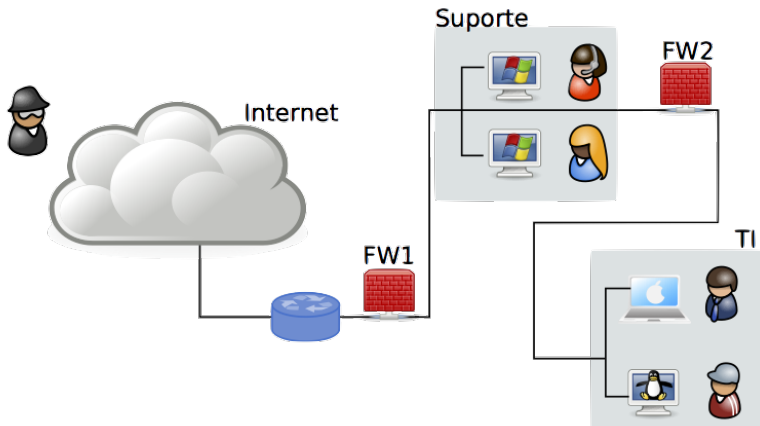
Estratégia: *Firewall* com 2 interfaces



Estratégia: Firewall com subredes



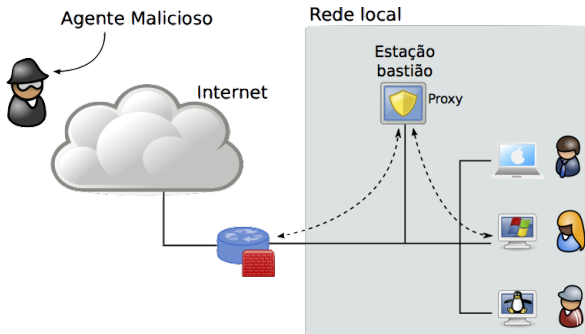
Estratégia: 2 Firewalls com subredes



Estação bastião

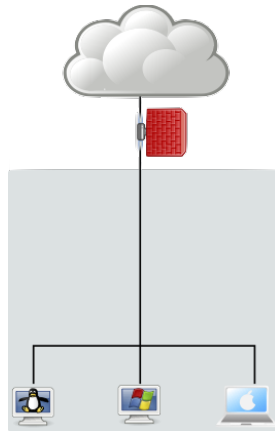
Bastion host

- Máquina com poucas aplicações em execução, projetada e configurada para resistir a ataques
 - Servidores proxy (SOCKS, HTTP, RTP, etc.)
- Somente pacotes oriundos e destinados a esta máquina podem passar pelo firewall



Organização da rede

- 1 **Somente com estações de trabalho**
 - Residências e pequenas empresas



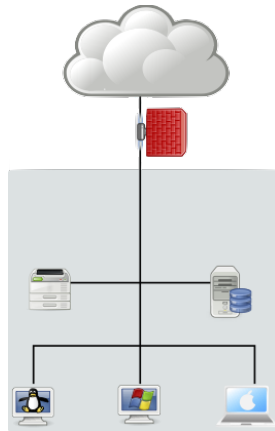
Organização da rede

1 Somente com estações de trabalho

- Residências e pequenas empresas

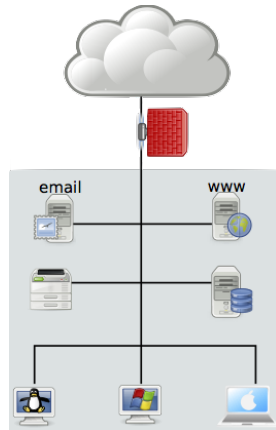
2 Estações e servidores internos

- Servidor de impressão, arquivos, etc.



Organização da rede

- 1 **Somente com estações de trabalho**
 - Residências e pequenas empresas
- 2 **Estações e servidores internos**
 - Servidor de impressão, arquivos, etc.
- 3 **Estações, servidores internos e externos**
 - WWW, SMTP, DNS, POP, IMAP, etc.



Organização da rede

1 Somente com estações de trabalho

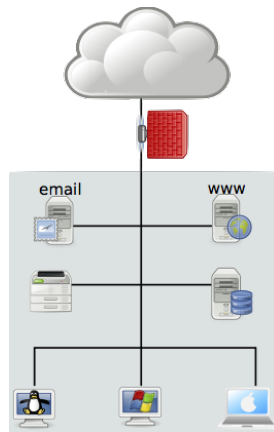
- Residências e pequenas empresas

2 Estações e servidores internos

- Servidor de impressão, arquivos, etc.

3 Estações, servidores internos e externos

- WWW, SMTP, DNS, POP, IMAP, etc.



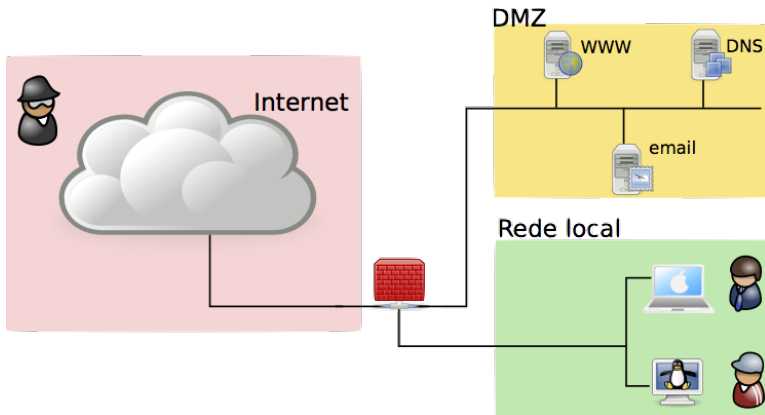
Como oferecer serviços externos sem que isto resulte em ameaças para a rede interna?

Zona desmilitarizada

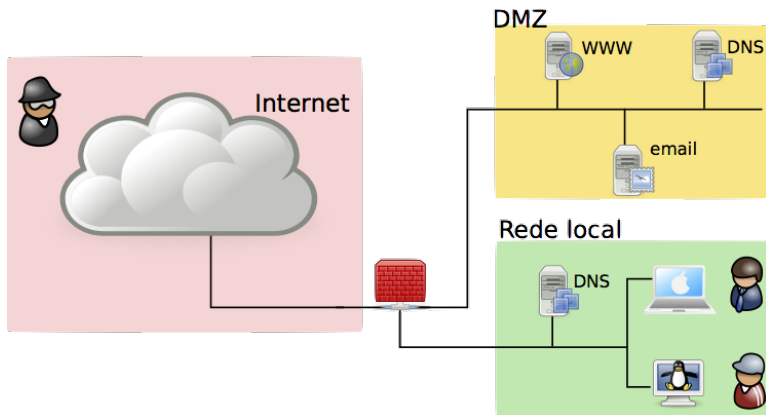
Demilitarized Zone (DMZ)

- Segmento de rede isolado entre a rede interna e a Internet, funcionando como uma **zona neutra**
- Protege a rede interna caso servidores acessíveis externamente sejam comprometidos
- Local indicado para hospedar serviços acessíveis tanto pela rede interna quanto pela Internet (ex: DNS, WWW, SMTP)
- Exige que os servidores na DMZ sigam rigorosamente as políticas de segurança e estejam sempre atualizados

Zona desmilitarizada



Replicar serviços pela DMZ e rede local



- Replicar serviços pela rede local e DMZ garante que se o servidor na DMZ for comprometido, isto não irá afetar os usuários da rede local
- Exemplo: Servidor de DNS apontando para máquinas maliciosas

Ataques que exploram vulnerabilidades de protocolos de rede

A Internet foi projetada para ser robusta, não segura

- **Internet foi projetada para ser**

- Aberta – qualquer dispositivo pode conectar
- Robusta – roteamento mesmo diante de falhas em dispositivos
- Escalável – crescer sem necessidade de reestruturar

- **Quando os protocolos foram propostos**

- Segurança não era uma preocupação, pois a rede era pequena e confiável

- **No final da década de 1990**

- IETF indica que a segurança seria responsabilidade dos usuários finais e não da rede
- Modelo de segurança fim-a-fim

Ataques

■ **Intercepção de tráfego**

- Sniffing
- Spoofing
- DNS spoofing ou cache poisoning
- BGP hijacking

■ **Ataques de negação de serviço (DoS)**

- IP spoofing (camada de rede)
- SYN flood (camada de transporte)
- Slow loris (camada de aplicação)

Intercepção de tráfego

Packet Sniffing

- *Sniffing* consiste em interceptar e analisar dados transmitidos na rede (Ethernet, Wi-Fi, Bluetooth, etc.)
- O atacante deve estar na mesma rede da vítima ou controlar um roteador intermediário
- Em redes sem fio, é possível capturar pacotes mesmo sem estar associado à rede
- É um **ataque passivo**, difícil de detectar; a principal defesa é o uso de criptografia (VPN, HTTPS, SSH, E2EE)
- Ferramentas comuns: Wireshark, tcpdump, Ettercap, Kismet

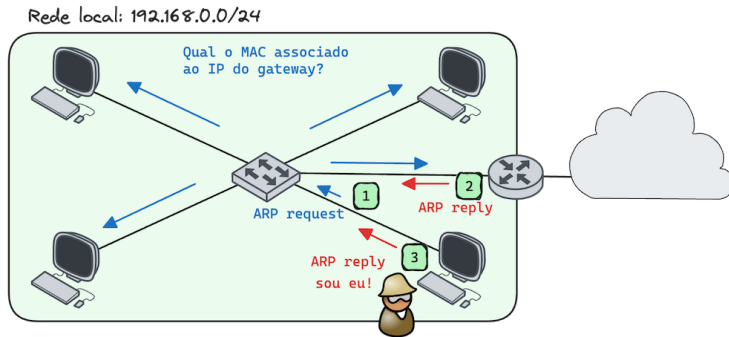
Intercepção de tráfego I

Spoofing

- *Spoofing* é a falsificação de identidade para enganar dispositivos ou usuários na rede
- Tipos comuns:
 - **ARP Spoofing:** Manipula o ARP para redirecionar tráfego
 - **IP Spoofing:** Falsifica endereços IP para mascarar o atacante
- É um ataque **ativo**: o atacante pode interceptar, modificar ou injetar pacotes

Intercepção de tráfego II

Spoofing



- No ARP spoofing, o atacante descobre o MAC do gateway e da vítima (ARP broadcast), depois envia respostas ARP falsas (defasadas) para atualizar o ARP cache da vítima e redirecionar o tráfego para ele

Intercepção de tráfego III

Spoofing

- **IP spoofing** em uma LAN é simples:
 - Se a máquina legítima estiver desligada, o atacante pode assumir seu IP e receber o tráfego.
 - Se estiver ligada, pode haver conflitos de IP e instabilidade
- Em redes diferentes, o atacante precisa controlar um roteador intermediário

Como fazer um ARP spoofing

- Descubra o IP da vítima e do gateway (roteador):

```
arp -a
```

- Use a ferramenta arpspoof (pode ser necessário instalar o pacote dsniff):

```
sudo arpspoof -i <interface> -t <IP-da-vítima> <IP-do-gateway>  
sudo arpspoof -i <interface> -t <IP-do-gateway> <IP-da-vítima>
```

- Pronto, utilize o Wireshark para capturar o tráfego entre a vítima e o gateway
- Para desfazer o ataque, limpe a tabela ARP dos dispositivos

Atenção

Realize este experimento apenas em ambientes controlados e autorizados

Intercepção de tráfego via *DNS poisoning*

- *DNS poisoning* corrompe o cache de um servidor DNS, inserindo registros falsos
 - O atacante redireciona o tráfego para servidores maliciosos, podendo interceptar, modificar ou bloquear dados
- O DNSSEC usa criptografia de chave pública para garantir autenticidade e integridade dos registros DNS

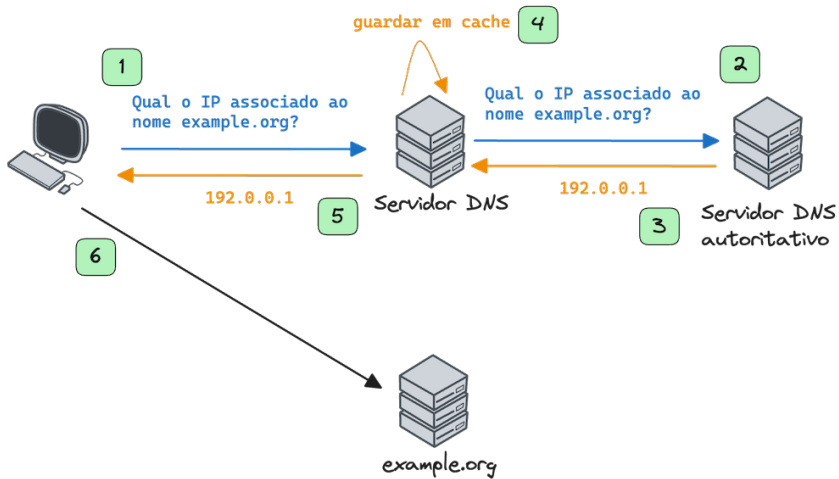
```
dig DNSKEY ifsc.edu.br          # Exibe a chave pública DNSSEC
dig +dnssec +short ifsc.edu.br  # Verifica se o domínio usa DNSSEC
```

- Ferramenta online: <https://dnssec-debugger.verisignlabs.com>

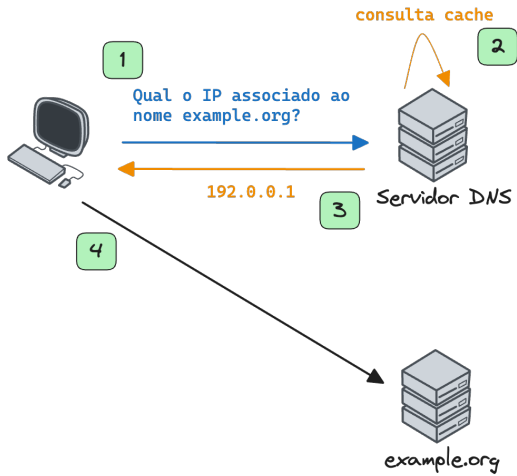
! Importante

Softwares maliciosos podem alterar o arquivo `hosts` do sistema ou as configurações de DNS do roteador

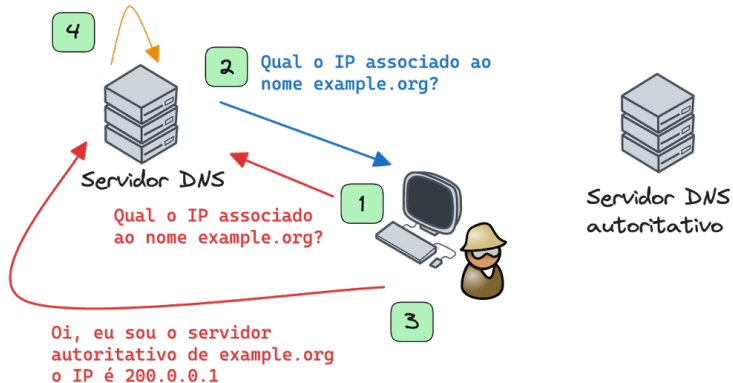
DNS poisoning



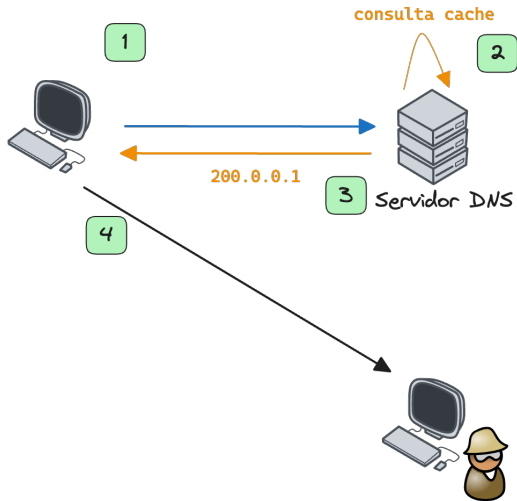
DNS poisoning



DNS poisoning



DNS poisoning



Sequestro de BGP

BGP hijacking

- O *Border Gateway Protocol* (BGP) é o protocolo de roteamento entre sistemas autônomos (AS) na Internet
- No BGP hijacking, um AS anuncia rotas falsas para um bloco de IP, desviando o tráfego para si ou para servidores maliciosos

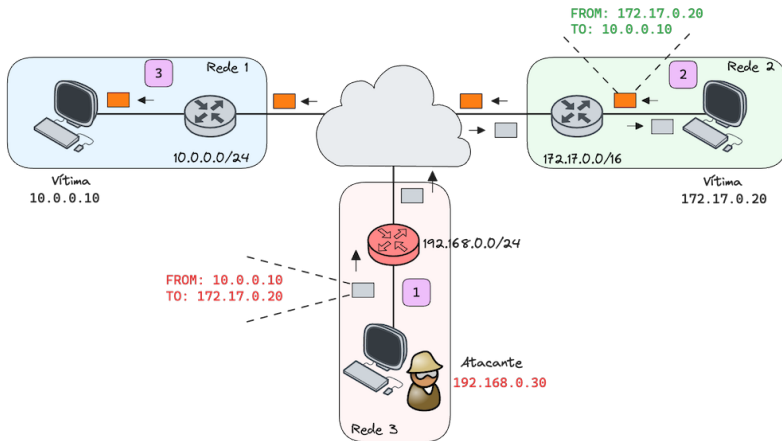
Exemplos de BGP hijacking

- 2010: China anunciou rotas para 15% do tráfego global por 18 minutos
- 2017: Rússia anunciou rotas para 7% do tráfego por 8 minutos
- Documentos revelados por Snowden mostram que a NSA explora falhas de BGP para interceptar dados

Ataque de negação de serviço (DoS)

- **IP spoofing** é mais comum em ataques de negação de serviço (DoS), onde o atacante forja o IP de origem para dificultar a identificação do atacante
- Só são possíveis porque as redes permitem *spoofing*
 - <http://bcp.nic.br/antispoofing>

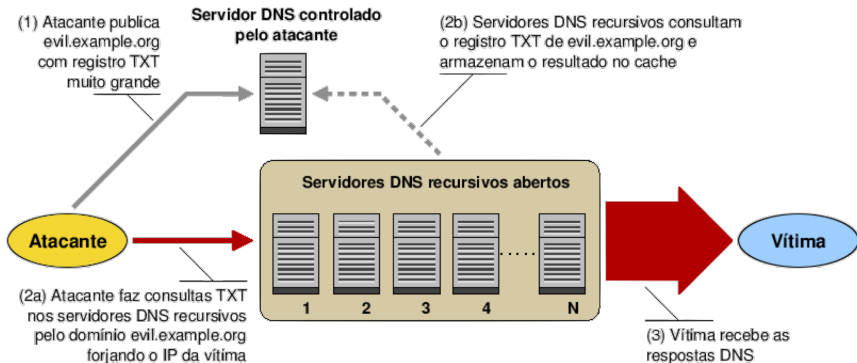
Ataque de negação de serviço (DoS) com IP spoofing



- Sobrecarrega um servidor com uma grande quantidade de tráfego (asimetria de tráfego: tráfego de saída é maior que o de entrada)

DrDoS - Amplificação de DNS

Por meio de servidores DNS recursivos abertos e IP *spoofing*

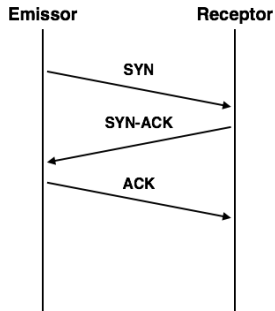


Fonte: <http://www.cert.br/docs/whitepapers/dns-recursivo-aberto/>

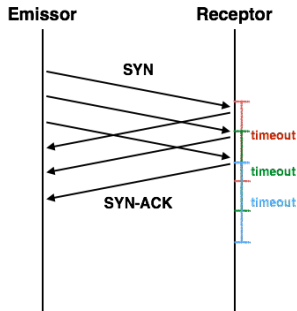
```
dig TXT apple.com # Veja o MSG SIZE rcvd:
```

Ataque SYN flood

Ataque de negação de serviço (DoS) na camada de transporte



Comportamento correto



Comportamento malicioso

- Não responde SYN-ACK com o ACK
- IP de origem forjado (IP spoofing)
- Vítima mantém conexões abertas até o *timeout*
- Trata-se de um ataque volumétrico

Slowloris

Ataque de negação de serviço (DoS) na camada de aplicação



- Alvo: servidor web baseado em conexões, p.e. Apache HTTP
- Atacante não precisa de muito recurso (rede e processamento)

